

COMPASS Dashboard

Speech-to-Text (STT) Feature

Technical & Security Report

Code Architecture · Model Licenses · Institutional Security Review

2026-09-25

Item	Detail
Feature	In-browser Speech-to-Text for Re-write Practice
STT Model	onnx-community/moonshine-base-ONNX (MIT License)
VAD Model	onnx-community/silero-vad (MIT License)
Inference Library	@huggingface/transformers v3.7.1 (Apache-2.0)
Audio exits browser?	NO — transcription only; audio stays in the browser tab
BAA required?	NO — no PHI transmitted to any third party

1. Executive Summary

The **Speak** button in the Re-write Practice panel transcribes spoken input into the rewrite text box. All processing — Voice Activity Detection (VAD) and automatic speech recognition (ASR) — runs **entirely inside the browser tab** using two ONNX models loaded from Hugging Face on first use and cached locally.

Microphone audio is never transmitted to the backend, to Hugging Face, or to any third party. Only the recognised text string is appended to the textarea. This design means **no Business Associate Agreement (BAA) is required** for the audio signal itself.

2. Architecture & Code Flow (9 Steps)

Step	File	What happens
1. Click Speak	RewriteVoiceInput.tsx	useSpeechToText.start() is called.
2. Security check	useSpeechToText.tsx:52	Checks window.isSecureContext (HTTPS required) and navigator.mediaDevices.getUserMedia.
3. Worker acquire	sttWorkerHost.ts:23	getSttWorker() returns a shared module-type Web Worker (stt.worker.ts). One worker per page.
4. Load models	stt.worker.ts:77	First click: downloads silero-vad (~2 MB) and moonshine-base-ONNX (~123 MB) from Hugging Face.
5. Open microphone	useSpeechToText.tsx:151	getUserMedia({ audio: { sampleRate:16000, echoCancellation:true, noiseSuppression:true } }) is called.
6. VAD scoring	stt.worker.ts:131	Every 512-sample frame -> Silero VAD returns speech probability. score>0.3=speech start.
7. Transcription	stt.worker.ts:230	Completed audio chunk -> Moonshine ASR returns {text}. Posted back as {type:'text', text}.
8. Append to textarea	sttConstants.ts	appendTranscript() appends text with smart spacing. No server call at this stage.
9. Stop	useSpeechToText.tsx:80	stream.getTracks().stop() releases microphone. AudioContext.close(). Worker stays alive (for next use).

Source files:

File	Role
src/lib/sttConstants.ts	Master switch (VOICE_INPUT_ENABLED), model IDs, audio tuning, appendTranscript()
src/lib/sttWorkerHost.ts	Singleton worker — created once, kept alive between dictations
src/workers/stt.worker.ts	All ML inference: VAD frame scoring, sentence detection, Moonshine transcription
src/hooks/useSpeechToText.tsx	Browser plumbing: permissions, AudioContext, AudioWorklet, worker messaging
src/components/RewriteVoiceInput.tsx	UI: Speak button, status label, warning banner
public/vad-processor.js	AudioWorklet: 512-sample rechunking + Firefox 16 kHz resampler
next.config.js	Webpack: stubs out onnxruntime-node, keeps ORT bundle un-minified

3. Models & Licenses

Component	Identifier	License	Commercial Use
STT model	onnx-community/moonshine-base-ONNX	MIT	Free — no restrictions
Original STT	UsefulSensors/moonshine-base	MIT	Free — no restrictions
VAD model	onnx-community/silero-vad	MIT	Free — no restrictions
Library	@huggingface/transformers v3.7.1	Apache-2.0	Free + patent grant

Conclusion: MIT and Apache-2.0 are fully permissive licenses. No copyleft, no usage fees, no attribution requirement beyond retaining license notices. Suitable for clinical research and commercial institutional deployment.

4. Network Traffic

Event	Destination	Protocol	Size	Frequency
First Speak click (model download)	cdn-lfs.huggingface.co	HTTPS 443	~125 MB total	Once — cached afterwards
Subsequent clicks	(none)	—	0 bytes	Served from browser cache
During dictation	(none)	—	0 bytes	Audio stays in browser
Score button click	COMPASS server (:18001)	HTTPS	Text only	On doctor request

Domains to whitelist: huggingface.co · cdn-lfs.huggingface.co · cdn-lfs-us-1.huggingface.co (all port 443 HTTPS)

5. Browser Compatibility

Browser	Support	Notes
Chrome / Edge 89+	Full	WebGPU when available; WASM fallback. Native 16 kHz AudioContext.
Safari 16.4+	Full	AudioWorklet stable from Safari 14. 16 kHz context natively.
Firefox 76+	Partial	No 16 kHz AudioContext — vad-processor.js resamples. No WebGPU → WASM only (~2x slower)
HTTP (non-HTTPS)	Blocked	getUserMedia() unavailable. Code shows 'Voice input needs HTTPS'.
Internet Explorer / old Edge	None	No AudioWorklet, no module Workers.

6. Security & Institutional Review

6.1 Positive security properties

Property	Detail
Audio never leaves browser	Microphone audio stays in the Web Worker. Only plain-text result crosses to the page.
No third-party audio upload	No API call to Google, AWS, Azure, or any external speech service.
Microphone released on Stop	getTracks().stop() called immediately — browser mic indicator clears.
No SharedArrayBuffer	Not used. COOP/COEP headers are NOT required and NOT set.
HIPAA/PHI audio safe	Audio is PHI (physician voice). Because it never leaves the device, no BAA is needed for the STT feature.
Session isolation	{type:'reset'} clears in-flight transcriptions on Stop. No cross-dictation data bleed.

6.2 Institutional risk table

Risk	Level	Details & Mitigation
HuggingFace CDN blocked by firewall	HIGH	Models (~125 MB) downloaded from cdn-lfs.huggingface.co on first use. Button stays in 'Loading...' state. Mitigation: Whitelist cdn-lfs*.huggingface.co:443 OR host models locally on the COMPASS server.
WebAssembly blocked by EDR/DM policy	RED/DM	ONNX Runtime uses WASM as primary compute backend. Enterprise security tools may block .wasm. Mitigation: Allow WebAssembly for compass.hlpgonzalezlab.com in browser policy.
EDR heuristic alert on large CDN download	LOW	~125 MB binary from external CDN triggered by a medical app may flag behavioral detection. Mitigation: Whitelist CDN domains in EDR policy. One-time event.
Module-type Web Worker blocked	MEDIUM	Worker created as type:'module'. Enterprise Chrome/Edge policies may restrict this. Mitigation: Verify COMPASS origin is in allowed worker origins list.
AudioWorklet CPU spikes	LOW	Audio thread runs while microphone is open. May trigger DLP tools monitoring sustained CPU + mem. Mitigation: Acceptable — microphone is user-initiated and released on Stop.
Browser cache quota (~125 MB)	LOW	Disk quota policies may evict models after browser close. Requires re-download next session. Mitigation: Accept periodic re-download, or host models locally.
SharedArrayBuffer / COOP+COEP	GREEN	Not used. No isolation headers required. App works without cross-origin isolation.
Audio data to third party	NONE	Zero audio bytes leave the browser. Confirmed by code review of stt.worker.ts and useSpeechToText.

6.3 Memory profile

Metric	Value	Notes
First download	~125 MB	One-time; cached in Browser Cache API
RAM (models loaded)	~700 MB	Worker kept alive between dictations to avoid reload delay
CPU during dictation	Moderate	AudioWorklet on audio thread + VAD in worker
CPU at transcription	High (brief)	Moonshine inference on sentence completion (~1–3 sec)
Network after cache	0 bytes	Fully offline once models are cached

7. Recommendations

#	Action	Priority
1	Whitelist at firewall: huggingface.co, cdn-lfs.huggingface.co, cdn-lfs-us-1.huggingface.co (port 443) OR Required for first-time model download	CRITICAL

2	Allow WebAssembly in browser policy for compass.hlggonzalezlab.com. Check Chrome Enterprise WebAssembly policy setting.	HIGH
3	Host models locally on COMPASS server to eliminate CDN dependency (~125 MB). One-line change in Constants.ts.	MEDIUM
4	Add EDR whitelist entry for COMPASS origin performing large binary downloads from HuggingFace CDN.	MEDIUM
5	Inform IT: ~700 MB RAM held by browser tab after first Speak click. Expected — not a memory leak	LOW
6	Train users: first click may show 'Loading...' for 1–3 min on slow connections. Subsequent sessions are instant.	LOW

8. Summary

The COMPASS STT feature is **architecturally sound from a privacy and security standpoint**. Audio never leaves the browser, no PHI is transmitted externally, and no BAA is required for audio processing. All component licenses (MIT, Apache-2.0) are fully permissive and appropriate for institutional clinical research use.

The primary operational risks are **institutional network and policy controls** — specifically firewall rules blocking HuggingFace CDN and endpoint security restricting WebAssembly. These are solvable with targeted whitelisting, or by hosting model files locally on the COMPASS server.

No code changes are required for compliance. The feature is ready for clinical use in HTTPS-served environments where the above network/policy conditions are met.